

INFORME DE AUDITORIA

TECNICA DE SEGURIDAD WEB

Análisis de seguridad perimetral, nivel de exposición y vulnerabilidades.



Heimdall Threat Advisory

Consultoría en ciberseguridad para empresas

Organización auditada: e-commerce.com
Auditoria de seguridad

INFORME DE AUDITORIA TECNICA DE SEGURIDAD WEB (ACTIVO ÚNICO)

Fecha del informe: Junio-01-2026.

Periodo de auditoria: [Mayo-15-2026]-[Mayo-31-2026].

Entidad auditada: e-commerce.com

Auditor: José Ricardo Flores Martínez.

Responsable	Puesto	Fecha de entrega
	Director general	Junio 01 2026
	Gerente IT	Junio 01 2026
	Responsable de desarrollo	Junio 01 2026

Índice de contenido.

- 1. Pag 2 - Resumen ejecutivo (motivación, alcance y objetivos).
- 2. Pag 4 – Metodología (Framework base de auditoria).
- 3. Pag 4 - Recopilación de información abierta.
- 4. Pag 7 - Enumeración de puertos (Comandos y parámetros de escaneo).
- 5. Pag 8 – Hallazgos (Información detallada de las evidencias encontradas).
- 6. Pag 9 - Confirmación mediante pruebas de concepto.
- 7. Pag 12 - Conclusiones de auditoría.
- 8. Pag 13 – Anexo (Capturas de ejecución y resultados de pruebas).

1. Resumen ejecutivo.

El presente informe de auditoría técnica corresponde al proceso análisis de exposición, enumeración y prueba de servicios expuestos a internet, buscando identificar posibles riesgos críticos de seguridad presentes en la arquitectura y configuración de los mismos, así como de la infraestructura que los soporta (servidores, seguridad de red, etc.).

Se asigna una clasificación de riesgo validado global correspondiente a 55 (**nivel moderado**) basándose en factores como subdominios expuestos fuera del perímetro de seguridad WAF que permiten enumeración de puertos, acceso a los paneles de administración y la presencia de tecnologías obsoletas o sin soporte activo que incrementan la superficie de ataque. Este nivel corresponde al promedio de las condiciones de riesgo individuales.

- **Razón principal:** Se realizó un proceso de rastreo de direcciones IP para la plataforma comercial determinando que la infraestructura se encuentra protegida por un servicio WAF gestionado por Cloudflare que enmascara la dirección real del servidor. Sin embargo, mediante procesos de investigación de información abierta OSINT se localizó 1 subdominio fuera del perímetro de protección contratado. Se determinaron y analizaron 2 condiciones de riesgo principales relacionadas con los puntos considerados como de mayor riesgo que si bien, no pudieron ser explotadas con las pruebas aplicadas, su presencia y la aplicación de pruebas sin respuestas indicativas de mecanismos activos de detección o contención a nivel perimetral siguen presentando un punto de riesgo latente.
- **Recomendación urgente:** Se determina que la infraestructura cuenta con modelo de seguridad parcialmente segmentado que combina tecnologías antiguas sin soporte activo, con protecciones modernas como el panel de administración o la protección WAF que, si bien protege y limita correctamente muchas de las interacciones, mantiene expuestos accesos directos desde fuera del perímetro sin una aparente ejecución consistente de mecanismos de detección o restricción.

Acciones prioritarias:

1. Realizar una **revisión integral de puertos expuestos**, en especial los referentes al panel de administración.
2. Asegurar que todos los servicios críticos estén protegidos dentro del mismo perímetro de seguridad
3. Eliminar información innecesaria en los encabezados que puedan exfiltrar datos sobre tecnologías, versiones, etc.
4. Estandarizar las políticas de seguridad de acceso

Finalmente, se concluye que el principal riesgo no radica únicamente en vulnerabilidades individuales, sino en la **exposición del activo fuera del perímetro de seguridad**, lo que permite a un atacante identificar y evadir los controles implementados por el proveedor sin conocimiento del administrador para ejecutar acciones de reconocimiento, enumeración y solicitudes sin validación.

Clasificación de condiciones de riesgo analizadas.

Título de vector analizado	Confirmación de explotabilidad	Nivel de riesgo validado
Exposición de activo origen fuera del WAF	Confirmada	90 – Critico
Manipulación de ruta en backend (parámetros manipulables).	No explotable	45 - Moderado
Bypass parcial WAF - Panel de administración expuesto.	Mitigación parcial	45 - Moderado
Uso de tecnologías obsoletas o en estado EOL.	No explotable	65 - Alto
Ausencia de sanitización de metadatos en archivo	Confirmada	30 - Bajo
Índice de riesgo general	Requiere atención	55 - Moderado

El nivel de riesgo se determina en dos etapas, primero se asigna un nivel de **riesgo inherente**, directamente relacionado a la condición de riesgo detectada sin considerar los controles de seguridad observados, para este se utiliza como base el CVSS asignado cuando corresponde, o se genera un calculo equivalente utilizando este estándar. Luego de la implementación de las pruebas de concepto, se genera el nivel de **riesgo validado**, el cual se genera teniendo en cuenta el contexto, obsolescencia tecnológica, controles observables, etc.

El riesgo validado se calcula de acuerdo con la siguiente métrica.

Nivel 1(0 - 20): Riesgo insignificante / informativo.

Nivel 2 (21 - 40): Riesgo bajo / asumible.

Nivel 3 (41 - 60): Riesgo moderado / requiere atención.

Nivel 4 (61 - 80): Riesgo alto / requiere mitigación urgente.

Nivel 5 (81 - 100): Riesgo crítico / inaceptable.

1.1 Alcance y objetivo:

Se realiza una auditoria de caja negra al dominio de internet provisto con el fin de determinar la presencia de posibles vulnerabilidades, configuraciones inseguras o puntos de acceso a la infraestructura.

Se analizó la dirección IP correspondientes al sitio e-commerce y direcciones derivadas del proceso de investigación y enumeración.

Bajo ningún concepto se ejecutaron actividades que pudieran afectar los activos, información o las actividades del negocio generando denegación de servicios o modificación permanente en configuraciones. Tampoco se almacena ningún tipo de información obtenida durante el proceso de auditoría.

El fin último de este proceso es aportar la mayor cantidad de información útil y veraz para la remediación de cualquier hallazgo encontrado que afecte la confidencialidad, disponibilidad e integridad de la información o que pueda poner en riesgo la continuidad del negocio.

2. Metodología:

Para el análisis de seguridad y determinación de vulnerabilidades se utilizó la como marco principal la metodología PTES (Penetration Testing Execution Standard) realizando.

Interacciones previas al compromiso (Pre-engagement): Definición del alcance, objetivos, límites, y acciones legales antes de iniciar la auditoría.

Recopilación de inteligencia (Intelligence Gathering): Obtención de información sobre el objetivo mediante fuentes abiertas (OSINT) o técnicas activas.

Modelado de amenazas (Threat Modeling): Análisis de los activos críticos y las posibles amenazas para definir los escenarios de ataque más viables.

Análisis de vulnerabilidades (Vulnerability Analysis): Identificación de fallos de seguridad en los sistemas utilizando herramientas automatizadas y análisis manual.

Explotación (Exploitation): Ejecución de pruebas técnicas para confirmar la explotabilidad de las condiciones de riesgo.

Post-Explotación (Post-Exploitation): Omitido, no se realiza ningún tipo de actividad permanente.

Informe (Reporting): Documentación detallada de los hallazgos, riesgos, evidencia de la explotación y recomendaciones de remediación.

3. Recopilación de información abierta:

3.1: Interacciones previas.

Al ser un ejercicio de “caja negra” y con el fin de simular un ataque real, únicamente se utiliza la URL del sitio comercial que se está auditando el cual corresponde a un sitio tipo e-commerce que alberga marquesinas de productos disponibles por localidad, con opción de seleccionar un producto y visualizar los detalles e imágenes representativas del mismo.

3.2: Recopilación de información.

Se realizan pruebas de *footprinting* para determinar la dirección IP asociada obteniendo las 2 direcciones listadas a continuación, las cuales, mediante un proceso de resolución inversa confirma que pertenecen al servicio de hosting **cloudflare** por lo que la infraestructura frontal utiliza Cloudflare como capa de protección y proxy reverso.

Esto se confirma mediante la consulta de los registros **whois** para la IP.

Dirección	IP Asignada	Estado	Servicio
e-commerce.com	172.xx.xx.244	Enmascarada WAF detectado	Cloudflare
e-commerce.com	104.xx.xx.51	Enmascarada WAF detectado	Cloudflare

Evidencia 3.1: Determinación de IP (dig) y resolución inversa

```
(kali@kali)~$ dig laboutique.vip
; <<> DiG 9.20.20-1-Debian <<> laboutique.vip
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 64697
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 4096
;; COOKIE: b03dfc93d05c517b5b150ef36a10cba2c659427200bdb278 (good)
;; QUESTION SECTION:
;laboutique.vip. IN A
;; ANSWER SECTION:
laboutique.vip. 300 IN A 172.17.3.1#53(172.17.3.1)
laboutique.vip. 300 IN A 104.17.3.1#53(104.17.3.1)
;; Query time: 64 msec
;; SERVER: 172.17.3.1#53(172.17.3.1) (UDP)
;; WHEN: Fri May 22 17:33:22 EDT 2026
;; MSG SIZE rcvd: 103

(kali@kali)~$ dig -x 104.17.3.1
; <<> DiG 9.20.20-1-Debian <<> -x 104.17.3.1
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 56947
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 4096
;; COOKIE: 45acac259c91103c1b4e729f6a10cbb7fe4c1c800b2a9a4f (good)
;; QUESTION SECTION:
;51.104.in-addr.arpa. IN PTR
;; AUTHORITY SECTION:
51.104.in-addr.arpa. 3600 IN SOA cruz.ns.cloudflare.com. dns.cloudflare.com. 2288625502 10000 2400 604800 3600
;; Query time: 264 msec
;; SERVER: 172.17.3.1#53(172.17.3.1) (UDP)
;; WHEN: Fri May 22 17:33:43 EDT 2026
;; MSG SIZE rcvd: 144
```

3.3. Exposición de origen server mediante Historial DNS:

Mediante la búsqueda DNS histórica se determinó que, aun cuando el dominio principal utiliza el servicio **cloudflare**, el subdominio correspondiente al servicio de correo “mail.e-commerce.com” cuenta con un registro **CNAME** que apunta hacia el alias **ba29.terabalance.cloud** el cual se resuelve a una dirección IPv4 provista por el ISP Vodafone ubicada en Huelva España.

Dirección	IP Asignada	Estado	Servicio
mail.e-commerce.com	85.137.48.75	Activa: Última det. Mayo 2026	Vodafone

El análisis de la aplicación nos confirma que el sitio está construido con tecnología PHP utilizando una estructura de scripts centralizados que recibe instrucciones como parámetros para localizar la información e imágenes en el DD para luego renderizar el sitio con la información correspondiente.

El sitio también permite la descarga de las imágenes de productos. Al aplicar el proceso de extracción de metadatos relacionados al archivo se detecta que estos no están debidamente sanitizados, conservando

información como, software de creación, fecha de modificación y en particular, el nombre original del archivo y autor, lo que facilita actividades de ingeniería social dirigida o investigación OSINT.

Evidencia 3.2: Extracción de metadatos

```
$ exiftool A7.jpg
ExifTool Version Number      : 13.50
File Name                    : A7.jpg
Directory                    : .
File Size                    : 320 kB
File Modification Date/Time   : 2026:05:19 22:07:11-04:00
File Access Date/Time        : 2026:05:19 22:08:39-04:00
File Inode Change Date/Time   : 2026:05:19 22:07:26-04:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
Exif Byte Order               : Big-endian (Motorola, MM)
Photometric Interpretation    : RGB
Orientation                   : Horizontal (normal)
Samples Per Pixel             : 3
X Resolution                  : 72
Y Resolution                  : 72
Resolution Unit               : inches
Software                     : Adobe Photoshop CS6 (Windows)
Modify Date                   : 2024:09:16 16:58:28
Exif Version                  : 0221
Color Space                   : Uncalibrated
Exif Image Width              : 500
Exif Image Height             : 997
Compression                   : JPEG (old-style)
Thumbnail Offset              : 394
Thumbnail Length              : 3139
Current IPTC Digest           : cdcffa7da8c7be09057076aeaf05c34e
Coded Character Set           : UTF8
Application Record Version    : 0
IPTC Digest                   : cdcffa7da8c7be09057076aeaf05c34e
```

3.4 Otros subdominios relacionados:

Aunque el análisis histórico de certificados reveló la existencia de otros subdominios correspondientes a servicio de soporte (posible contacto de ayuda al cliente), foro de comentarios y reseñas, así como nodos para balanceo de carga (posiblemente). Estos se encuentran debidamente protegidos por el WAF por lo que quedan fuera del alcance de la auditoría.

3.5 Confirmación de hipótesis de brecha perimetral y entorno obsoleto:

Al consultar la IP correspondiente al dominio de correo en SHODAN (plataforma de enumeración de IP), nos permite confirmar la ubicación geográfica perteneciente al ISP Vodafone, confirmando el **hostname** que apunta directamente a la IP consultada, lo que sugiere fuertemente que la aplicación web se aloja en este mismo servidor, posiblemente exponiendo la infraestructura backend fuera de la protección del proxy/WAF.

La huella de red revela un servidor web Apache HTTP Server junto con una combinación de puertos abiertos (2082, 2083, 2086, 2087, servicios de correo y DNS) los cuales se corresponden con el patrón clásico de un entorno administrado mediante cPanel / WebHost Manager (WHM).

Se realizaron pruebas de acceso mediante modificación directa de ruta en la aplicación web con el fin de determinar si hay riesgo de exfiltración por falla de tipo **path traversal**, dicha prueba genera un fallo en el renderizado del contenido aun cuando la solicitud se procesa de manera correcta validando la lógica del script `/filesaver` el cual está abierto a recibir entradas modificadas.

Para validar la viabilidad de interacción directa con la lógica del backend web omitiendo los controles perimetrales, se realizaron peticiones dirigidas mediante la utilidad **curl** forzando la solicitud de parámetros hacia el script centralizado. La respuesta del servidor no solo confirmó la recepción y procesamiento de solicitudes automatizadas mostrando un código HTTP 200 OK, sino que expuso en la cabecera X-Powered-By el uso de la versión **PHP/5.3.29**. Un entorno de ejecución oficialmente discontinuado, carente de soporte y sin mantenimiento de seguridad oficial.

Evidencia 3.3: Confirmación de versión de software (PHP 5.3.29).

```
HTTP/2 200
date: Fri, 22 May 2026 22:51:22 GMT
content-type: text/html; charset=UTF-8
server: cloudflare
x-powered-by: PHP/5.3.29
set-cookie: UNIQUE_USER_ID=8dfe3439e7b7f51a227e6346ebb63af3; expires=Sat, 22-May-2027 22:52:04 GMT; path=/; domain=.cloudflare.com
nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
cf-cache-status: DYNAMIC
report-to: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=A5%2B%2BIsYiEPAVYfi9m2CtgntBQBr4B%2BRPRlovXmoVSoSitreP7Siu0Bc4Fb7uzpyS2kIaBqETz6tJXoJeYa762U55Ij0FYHPWZWK7trNqGsq%2BWYTPkrMC27CXI5W0IFkqHtXIX3D"}]}
cf-ray: 9fff62986ad833ce-DFW
alt-svc: h3=":443"; ma=86400
```

4: Enumeración de puertos, fingerprint y elección de vectores.

Se complementa el análisis de estado de la infraestructura expuesta fuera del perímetro de protección WAF y se ejecutó un escaneo dirigido de huella de red (Fingerprinting). El análisis confirmó la disponibilidad de servicios críticos de administración, DNS y mensajería directamente en el nodo analizado.

PORT	STATE	SERVICE	VERSION
22/tcp	filtered	ssh	
53/tcp	open	domain	PowerDNS Authoritative Server 4.9.5
80/tcp	open	http	Apache httpd
110/tcp	open	pop3	Dovecot pop3d
143/tcp	open	imap	Dovecot imapd
443/tcp	open	ssl/http	Apache httpd
465/tcp	open	ssl/smtp	Exim smtpd 4.99.2
587/tcp	open	smtp	Exim smtpd 4.99.2
993/tcp	open	ssl/imap	Dovecot imapd
2082/tcp	open	cPanel (HTTP)	
2083/tcp	open	cPanel (HTTPS)	
2086/tcp	open	WHM (HTTP)	
2087/tcp	open	WHM (HTTPS)	

5. Hallazgos:

Con la información obtenida durante el proceso de enumeración de servicios se genera un análisis de las principales condiciones de riesgo, las cuales serán analizadas para confirmar si son explotables. Las condiciones seleccionadas para la implementación de las pruebas de concepto se enumeran a continuación.

5.1 Tecnología EOL: Se detecta la presencia de tecnologías antiguas sin soporte oficial activo combinada con un aparente procesamiento de datos sin mecanismos visibles de validación temprana en la entrada del script dinámico “/fileserver” (PHP/5.3.29), este comportamiento lo posiciona como el candidato prioritario y de mayor criticidad para pruebas de explotación de la brecha y el diseño de pruebas de concepto para validación de riesgo de exfiltración de archivos o ejecución remota de código (RCE) relacionados con la versión actual del servicio.

5.2 Superficie de exposición elevada: La aparente coexistencia de roles de servidor (Servidor de Aplicaciones Web, Servidor de Nombres de Dominio Autoritativo y Servidor de Correo Electrónico Completo MTA/MDA) sobre una misma dirección IP física incrementa drásticamente la superficie de ataque.

5.3 Entorno Compartido/VPS Administrado: La presencia activa de los servicios de cPanel y WHM (puertos 2082-2087) interactuando en conjunto con firmas de redirección hacia alias locales (ba29.terabalance.cloud), sugiere un despliegue del sistema en una arquitectura centralizada con limitada segregación perimetral observable desde el exterior.

La presencia combinada de tecnologías obsoletas o EOL, servicios de administración y múltiples puertos abiertos hacen que este activo sea considerado como de **alto riesgo** para la infraestructura (calificación modificada tras las pruebas de concepto aplicadas), ya que la explotación de al menos uno de los vectores detectados incrementa el riesgo de comprometer el activo en caso de confirmar la implementación no segregada de servicios.

6. Confirmación mediante pruebas de concepto:

Como método de confirmación se analizan los vectores de acceso principales mediante las siguientes pruebas de concepto con el fin de confirmar la posibilidad de explotación, la efectividad de los controles observables y configuraciones actuales.

1. Prueba de Concepto (PoC) para Extracción de Configuración: Documentar el payload exacto de Path Traversal simulando la lectura de archivos sensibles locales (como el wp-config.php, config.php del CMS o archivos del home de cPanel) aprovechando el comportamiento observado del backend con procesamiento aparente de parámetros manipulados durante la fase de validación.

2. Paneles de administración expuestos fuera de perímetro de seguridad: Se detecto exposición directa de los puertos estándar de administración apuntando al nodo del backend sin restricción de ACL o perímetros VPN visibles desde el exterior posibilitando intentos de autenticación automatizada, enumeración o pruebas de acceso no autorizadas.

3. Simulación de Subida e Inyección de Código (RCE): Teóricamente un formulario de carga de imágenes (como el analizado en los metadatos) podría ser utilizado para posicionar un script PHP funcional que otorgue acceso interactivo a la consola.

Esta prueba está limitada por las reglas de interacción para evitar modificaciones de archivos por lo que no fue implementada, se enumera como un punto de riesgo posible para el análisis y confirmación por parte del área responsable de desarrollo.

6.1. Tablas de validación y ejecución de pruebas:

A continuación, se listan las tablas de información y resultado al proceso de validación de las condiciones de riesgo seleccionadas. Se califican según el impacto.

Titulo	Prueba de manipulación de ruta en backend (parámetros manipulables).
Activo	Servidor Vodafone.
CVE-relacionada	No hay CVE relacionada. / Se analiza la CWE-22: Limitación inapropiada de accesos a directorios restringidos.
Nivel de riesgo inherente	Alto
CVSS 3.1	N/A
Evidencia técnica	Se realizaron una serie de pruebas controladas dirigidas al script de búsqueda y carga de contenido dinámico (/fileserver). Mediante solicitudes HTTPS directas al backend utilizando opciones de resolución directa de host (curl --resolve) con el fin de validar la capacidad de interacción fuera del perímetro cloudflare. El comportamiento observado durante la prueba confirma: • Recepción y procesamiento inicial de parámetros manipulados. • Persistencia de patrones <i>traversal</i> dentro de la lógica de redirección (../). • Ausencia de filtrado temprano observable sobre entradas potencialmente peligrosas al ser aceptadas por el script. • Interacción funcional directa con el backend web fuera de la capa WAF. Aunque no hubo exfiltración de datos, el servidor sigue aceptando solicitudes con datos modificados y potencialmente peligrosos ya que la lógica backend acepta parámetros manipulados, preservando patrones <i>traversal</i> dentro del flujo de ejecución antes de finalizar la respuesta.
Impacto	El riesgo inherente de la condición se considera alto ya que, la explotación de este vector o debilidades similares permitiría el acceso a archivos de configuración, administración y otros archivos críticos según la configuración del servidor y la segmentación de la información almacenada.
Corrección recomendada	Se recomienda actualizar a una versión más reciente, preferentemente con soporte activo, implementar validaciones estrictas de parámetros de entrada en el script y asegurar el acceso mediante IP confiables, implementación de ACLs y segmentación perimetral.
Explotación/confirmación	No explotable: Si bien el servidor aceptó las solicitudes con diferentes parámetros modificados que incluyeron patrones de modificación de ruta <i>path traversal</i> (../..) dentro del parámetro “archivo”, el servidor respondió consistentemente con el código HTTP 301 (Moved Permanently) aunque preservando íntegramente el payload suministrado dentro de la URL redirigida. Se asigna un valor de riesgo validado de 45 (Moderado) derivado de la obsolescencia técnica del servicio, actualmente en estado EOL.
Comentario	No se confirmó acceso arbitrario a los directorios probados ni exfiltración de archivos de configuración durante el proceso de prueba (ver anexo 1).

Titulo	Panel de administración expuesto (puertos: 2082, 2083, 2086, 2087)
Activo	Servidor Vodafone
CVE-relacionada	No hay CVE relacionada. / Se analiza la CWE-668: Exposición de un recurso a una esfera incorrecta.
Nivel de riesgo inherente	Alto
CVSS 3.1	N/A
Evidencia técnica	Mediante la herramienta Burp Suite, se intercepto la solicitud de acceso para determinar el comportamiento y capacidad de respuesta de la aplicación de administración utilizando credenciales invalidas para confirmar si es vulnerable a ataques de fuerza bruta. El comportamiento observado durante la ejecución de las pruebas muestra: • No se observaron mecanismos dinámicos visibles de validación anti-automatización en la solicitud interceptada. • No se observan tokens “nonce”, desafíos CAPTCHA o mecanismos anti-CSRF visibles durante el flujo inicial de autenticación. • No se observan restricciones visibles de acceso mediante ACL para limitar acceso desde IP seguras visibles desde el exterior. Sin embargo, la aplicación cuenta con un módulo propio de limitación de pruebas automatizadas (cPHulk Brute Force Protection) bloqueando las respuestas después de 5 intentos fallidos secuenciales degradando el tiempo de respuesta e interrumpiendo el envío de datos.
Impacto	La exposición directa a internet de paneles de administración de sistemas críticos permitiría la implementación de pruebas automatizadas, o en este caso la aplicación de intentos controlados según el tiempo de bloqueo de IP de la aplicación (6 horas según la documentación).
Corrección recomendada	Aun cuando los mecanismos de bloqueo de intentos secuenciales limitan el número de accesos incorrectos, se recomienda considerar mecanismos de prevención anti-automatización previos al procesamiento de la autenticación, además de la posibilidad de acceder al panel de administración desde cualquier IP mantiene un riesgo latente de pruebas de acceso no secuenciales.
Explotación/confirmación	Mitigación parcial por medidas de filtrado por tasa de repeticiones que impiden ataques de fuerza bruta masivos o rápidos. Se asigna un valor de riesgo validado de 45 (Moderado) derivado de la exposición directa de la plataforma a internet.
Comentario	Se degrada el nivel de riesgo de <i>Alto</i> a <i>Moderado</i> gracias a la efectividad del control de mitigación detectado. Sin embargo, se recomienda implementar acceso al panel únicamente desde direcciones de confianza. Intentos de acceso de tipo <i>spoofing DNS</i> pueden generar conflictos con la lista blanca de cPHulk (UseDNS setting) permitiendo ataques de fuerza bruta sin límite de intentos.

7. Conclusiones:

El análisis de resultados de las pruebas de concepto confirma la aplicación de varias medidas de hardening y buenas prácticas de configuración en los servicios de administración. Sin embargo, la existencia de servicios críticos accesibles desde fuera del perímetro de protección reduce bastante la efectividad de dichas medidas.

La dependencia de los métodos de bloqueo de accesos secuenciales y/o procesos de sanitización internos evidencia una **falta de visibilidad y control de superficie de ataque**, lo que permitiría evitar la aplicación de los controles implementados en la capa WAF y facilitaría la interacción directa con servicios del backend que se asumen protegidos por la capa perimetral.

Asimismo, la presencia de tecnologías obsoletas y la posible falta de compartimentación de servicios observable desde el exterior incrementa el riesgo de compromiso.

7.1: Prioridades de remediación.

Se recomienda priorizar las condiciones de riesgo confirmadas, principalmente la posibilidad de interacción sin pasar por el perímetro de protección WAF que permite eludir la protección contratada. También se recomienda fuertemente actualizar las tecnologías catalogadas como obsoletas o sin soporte activo ya que siguen siendo una fuente riesgo latente que incrementarían el riesgo de compromiso del activo en caso de una explotación exitosa. El orden de prioridad recomendado es:

1. Corrección inmediata de exposición de activo origen sin pasar por el perímetro WAF identificado
2. Eliminación de accesos directos al panel de administración
3. Actualización de tecnologías obsoletas (EOL)
4. Confirmar la implantación de medidas de seguridad y control de accesos como ACL
5. Sanitización de metadatos de archivos e imágenes.

8: Anexo de capturas de ejecución y resultados.

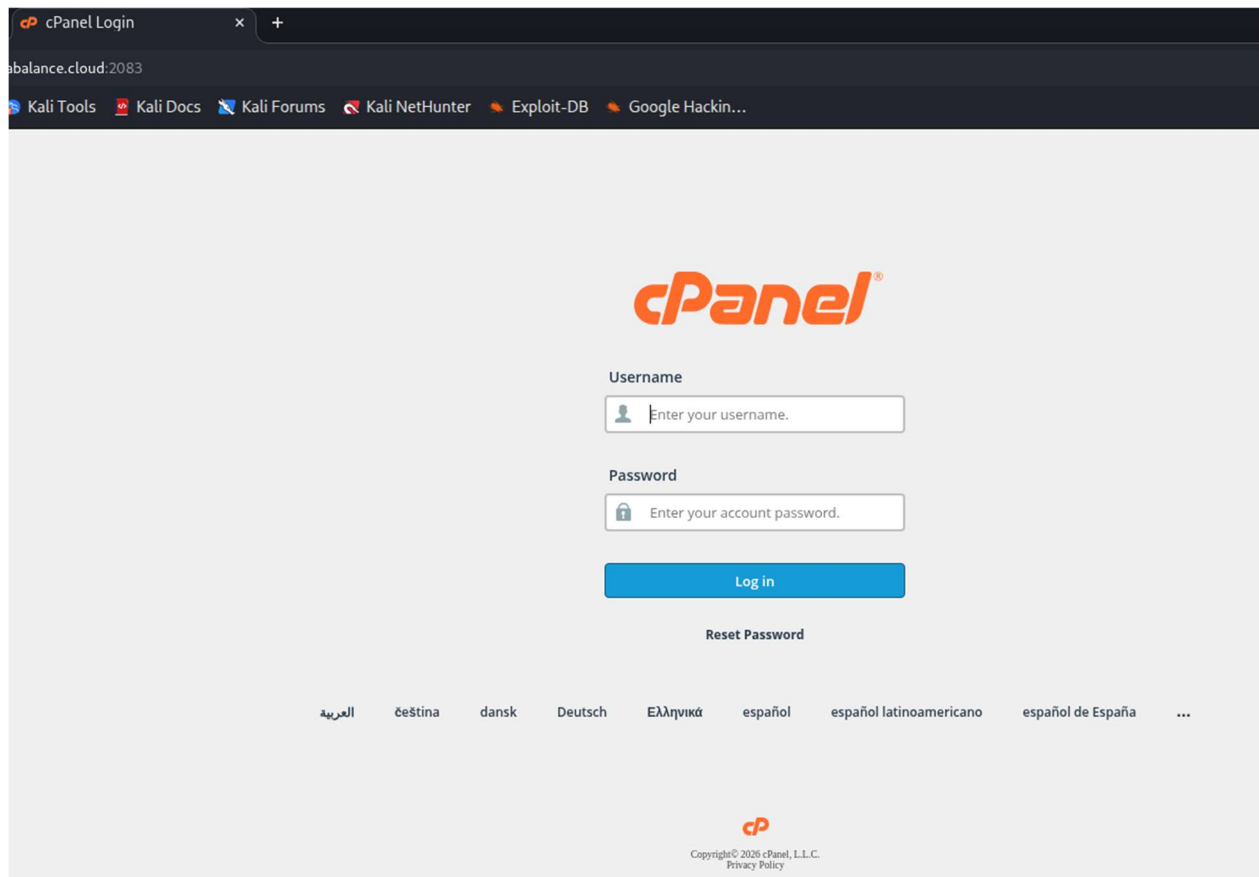
Evidencia PoC 01: Pruebas de solicitud de archivos con la herramienta **curl** usando parámetros modificados (path traversal).

```
(kali@kali)~$ curl -s -k -A "Mozilla/5.0" -H "Host: www.10.10.10.10" "https://85.137.48.75/fileserver?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="https://www.10.10.10.10/p/fileserver?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen">here</a>.</p>
</body></html>

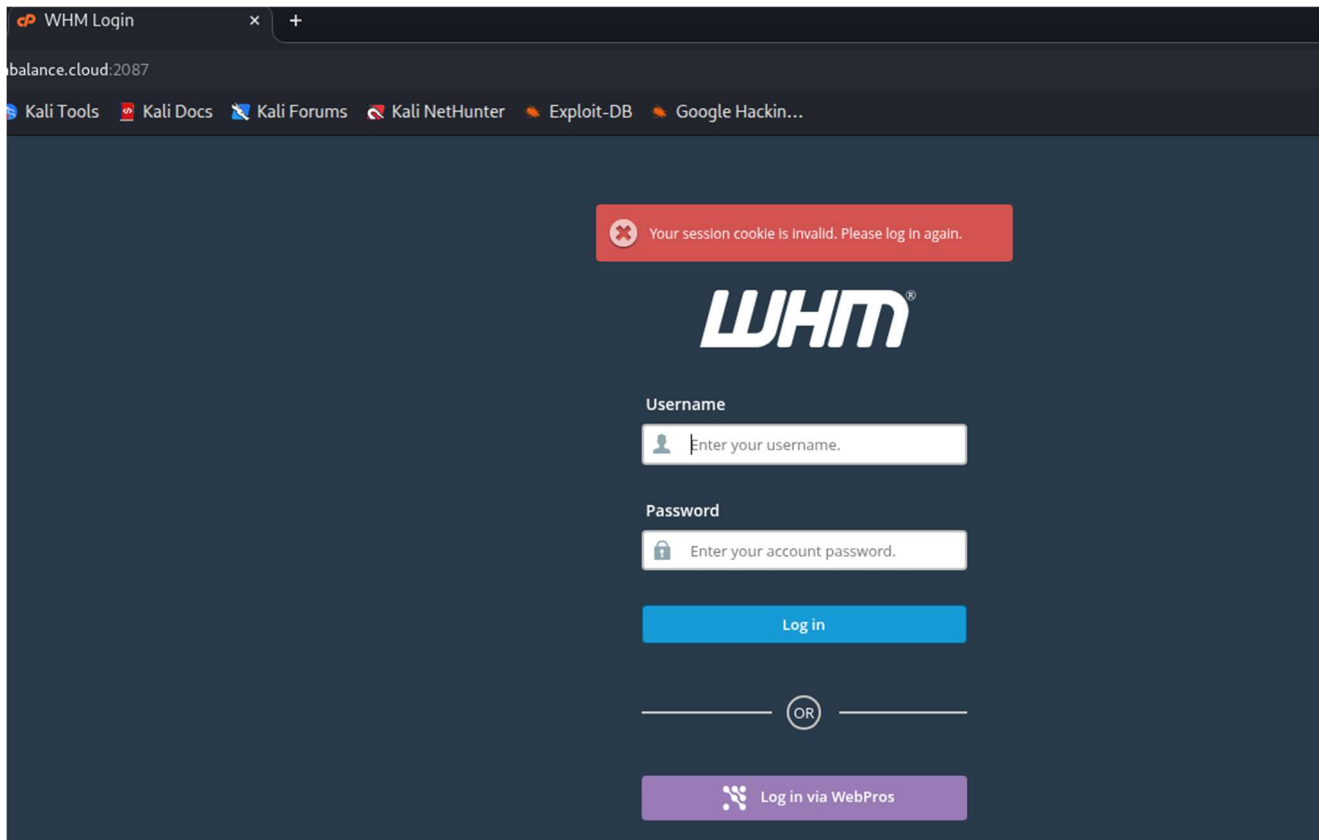
(kali@kali)~$ curl -s -k -L -A "Mozilla/5.0" --resolve www.10.10.10.10:443:85.137.48.75 "https://www.10.10.10.10/fileserver?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="https://www.10.10.10.10/p/fileserver?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen">here</a>.</p>
</body></html>

(kali@kali)~$ curl -s -k -L -A "Mozilla/5.0" --resolve www.10.10.10.10:443:85.137.48.75 "https://www.10.10.10.10/p/fileserver?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="https://www.10.10.10.10/p/fileserver.php?modo=mostrar_ventana&obtener_de=carpeta_de_modelo&id_modelo=164346&archivo=../../../../../../etc/passwd&tipo_archivo=imagen">here</a>.</p>
</body></html>
```

Evidencia PoC 02: Confirmación de acceso a panel administrativo por elusión parcial de protección WAF (cPanel).



Evidencia PoC 02.2: Acceso a panel administrativo por elusión parcial de protección WAF (WHM).



Evidencia PoC 02.3: Prueba de acceso y análisis de respuestas con BurpSuite.

